



Proxies

Many people have different opinions on what a proxy is:

- Security Professionals jump to **HTTP Proxies** (BurpSuite) or pivoting with a **SOCKS/SSH Proxy** (**Chisel**, **ptunnel**, **sshuttle**).
- Web Developers use proxies like Cloudflare or ModSecurity to block malicious traffic.
- Average people may think a proxy is used to obfuscate your location and access another country's Netflix catalog.
- Law Enforcement often attributes proxies to illegal activity.

Not all the above examples are correct. A proxy is when a device or service sits in the middle of a connection and acts as a mediator. The **mediator** is the critical piece of information because it means the device in the middle must be able to inspect the contents of the traffic. Without the ability to be a **mediator**, the device is technically a **gateway**, not a proxy.

Back to the above question, the average person has a mistaken idea of what a proxy is as they are most likely using a VPN to obfuscate their location, which technically is not a proxy. Most people think whenever an IP Address changes, it is a proxy, and in most cases, it's probably best not to

correct them as it is a common and harmless misconception. Correcting them could lead to a more extended conversation that trails into tabs vs. spaces, `emacs` vs. `vim`, or finding out they are a `nano` user.

If you have trouble remembering this, proxies will almost always operate at Layer 7 of the OSI Model. There are many types of proxy services, but the key ones are:

- `Dedicated Proxy` / `Forward Proxy`
- `Reverse Proxy`
- `Transparent Proxy`

Dedicated Proxy / Forward Proxy

The `Forward Proxy`, is what most people imagine a proxy to be. A Forward Proxy is when a client makes a request to a computer, and that computer carries out the request.

For example, in a corporate network, sensitive computers may not have direct access to the Internet. To access a website, they must go through a proxy (or web filter). This can be an incredibly powerful line of defense against malware, as not only does it need to bypass the web filter (easy), but it would also need to be `proxy aware` or use a non-traditional C2 (a way for malware to receive tasking information). If the organization only utilizes `Firefox`, the likelihood of getting proxy-aware malware is improbable.

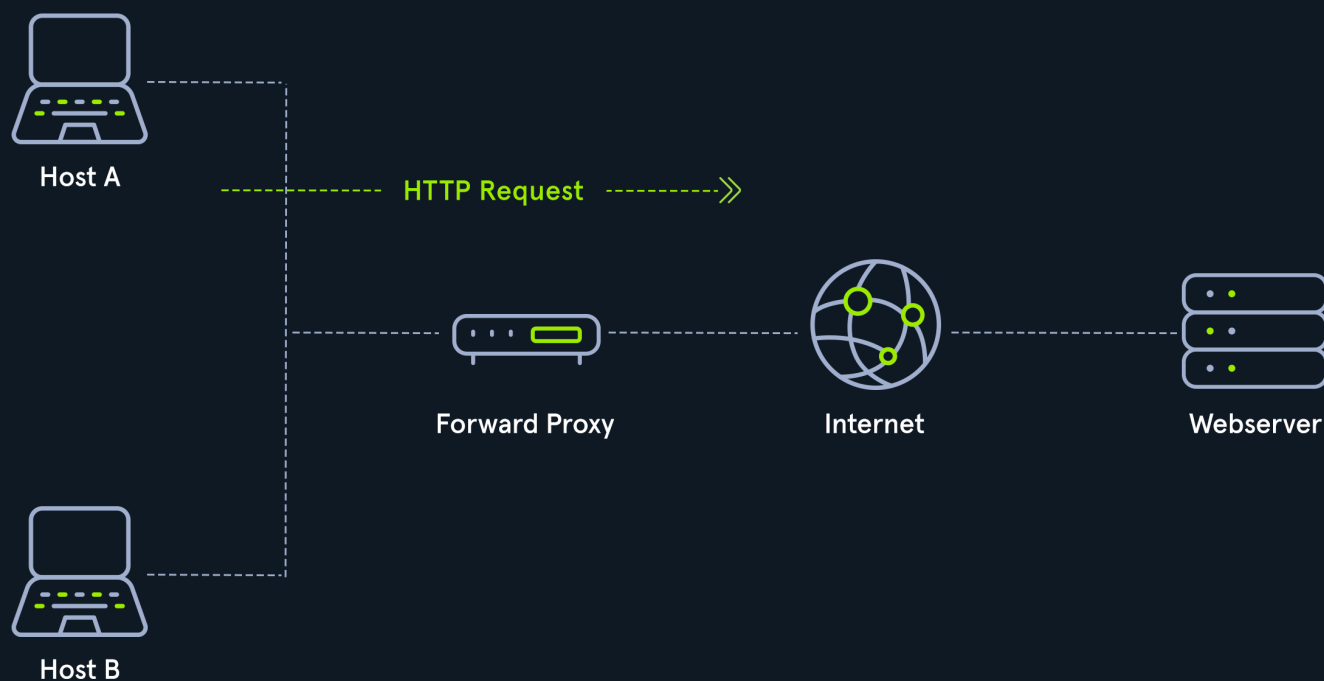
Web Browsers like Internet Explorer, Edge, or Chrome all obey the "System Proxy" settings by default. If the malware utilizes WinSock (Native Windows API), it will likely be proxy aware without any additional code. Firefox does not use `WinSock` and instead uses `libcurl`, which enables it

to use the same code on any operating system. This means that the malware would need to look for Firefox and pull the proxy settings, which malware is highly unlikely to do.

Alternatively, malware could use DNS as a c2 mechanism, but if an organization is monitoring DNS (which is easily done using **Sysmon**), this type of traffic should get caught quickly.

Another example of a Forward Proxy is Burp Suite, as most people utilize it to forward HTTP Requests. However, this application is the swiss army knife of HTTP Proxies and can be configured to be a reverse proxy or transparent!

Forward Proxy



Reverse Proxy

As you may have guessed, a **reverse proxy**, is the reverse of a **Forward Proxy**. Instead of being designed to filter outgoing requests, it filters incoming ones. The most common goal with a **Reverse Proxy**, is to listen on an address and forward it to a closed-off network.

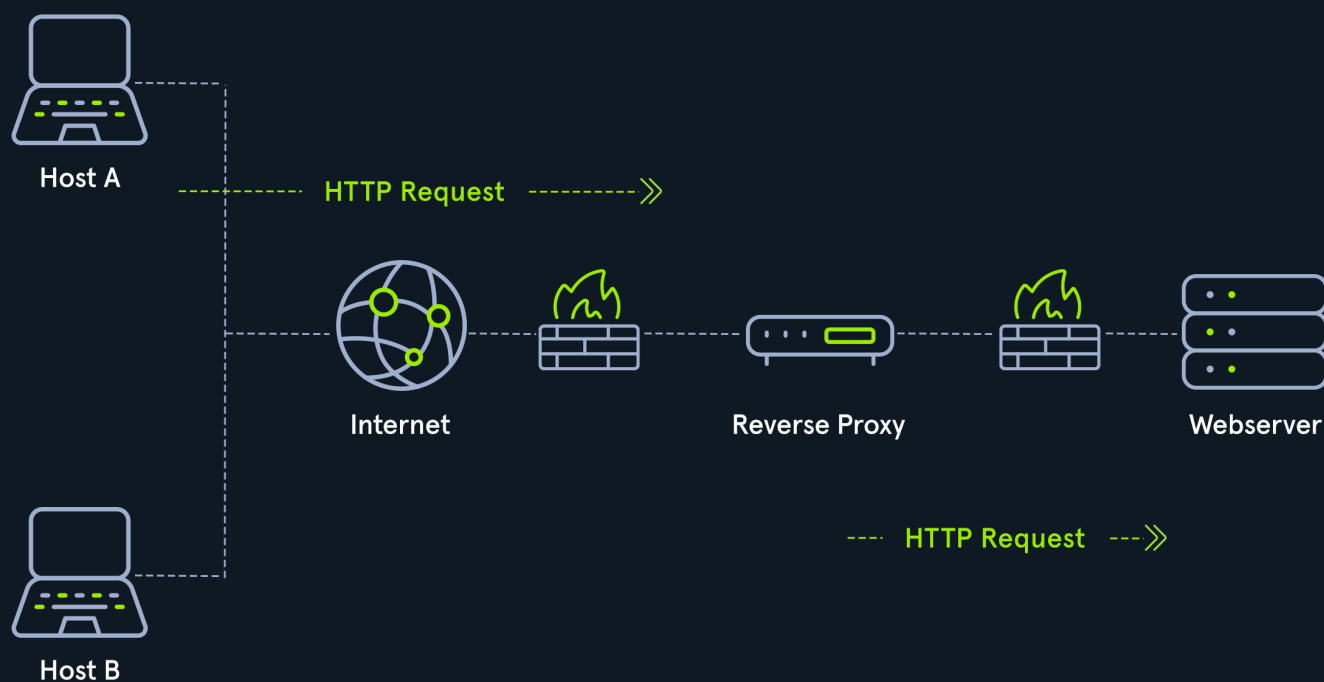
Many organizations use CloudFlare as they have a robust network that can withstand most DDOS Attacks. By using Cloudflare, organizations have a way to filter the amount (and type) of traffic that

gets sent to their webserver.

Penetration Testers will configure reverse proxies on infected endpoints. The infected endpoint will listen on a port and send any client that connects to the port back to the attacker through the infected endpoint. This is useful to bypass firewalls or evade logging. Organizations may have **IDS** (**Intrusion Detection Systems**), watching external web requests. If the attacker gains access to the organization over SSH, a reverse proxy can send web requests through the SSH Tunnel and evade the IDS.

Another common Reverse Proxy is **ModSecurity**, a **Web Application Firewall (WAF)**. Web Application Firewalls inspect web requests for malicious content and block the request if it is malicious. If you want to learn more about this, we recommend reading into the **ModSecurity Core Rule Set**, as its a great starting point. Cloudflare, also can act as a WAF but doing so requires letting them decrypt HTTPS Traffic, which some organizations may not want.

Reverse Proxy



(Non-) Transparent Proxy

All these proxy services act either **transparently** or **non-transparently**.

With a **transparent proxy**, the client doesn't know about its existence. The transparent proxy intercepts the client's communication requests to the Internet and acts as a substitute instance. To the outside, the transparent proxy, like the non-transparent proxy, acts as a communication partner.

If it is a **non-transparent proxy**, we must be informed about its existence. For this purpose, we and the software we want to use are given a special proxy configuration that ensures that traffic to the Internet is first addressed to the proxy. If this configuration does not exist, we cannot communicate via the proxy. However, since the proxy usually provides the only communication path to other networks, communication to the Internet is generally cut off without a corresponding proxy configuration.



4 / 21 Sections



Mark Complete & Next